GERMAN-MALAYSIAN INSTITUTE
Training for Advanced Technology

COMPUTER & INFORMATION DEPARTMENT

CBS 2353 - Penetration Testing

1.2.6 Lab

Compare Pentesting Methodologies

Student's Name	**ABDUL HARIZ B. MOHD SARNUDIN**
ID Number	**CBS24070208**
Trade/Group/Sem	**DCBS / CBS 1 / SEMESTER 4**
TTO's Name	**Ts Noormelah Shamsul**

1.1

Step 1: Gather information about OSSTMM.

In this step, you will learn about the Open Source Security Testing Methodology Manual (OSSTMM), which includes a complete methodology for security assessment.

a. Navigate to https://www.isecom.org, click **RESEARCH** > **OSSTMM**.
b. On the OSSTMM main page, view the OSSTMM document.

What is the latest version of the manual and its copyright date?

Answer Area

OSTMM Version 3, copyright date of 2010.

Show Answer

1.2

Although OSSTMM is old, it is still a good starting off point for planning and conducting security tests and audits. It is important however to use it in combination with more up-to-date standards and methodologies.

What organization develops the OSSTMM? What do they do?

Answer Area

ISECOM

Show Answer

1.3

What are the stated primary and secondary purposes of the OSSTMM as stated in the OSSTMM publication?

Answer Area

Primary : to provide a scientific methodology for the accurate characterization of operational security (OpSec).
Secondary : to provide guidelines which when followed will

Show Answer

Answers :

Primary : to provide a scientific methodology for the accurate characterization of operational security (OpSec).
Secondary : to provide guidelines which when followed will allow the auditor to provide a certified OSSTMM audit.

1.4

What six outcomes are assured then the OSSTM guidelines are correctly followed?

Answer Area

1. The test was conducted thoroughly.
2. The test included all necessary channels.
3. The posture for the test complied with the law.

Show Answer

Answers :

1. The test was conducted thoroughly.
2. The test included all necessary channels.
3. The posture for the test complied with the law.
4. The results are measurable in a quantifiable way.
5. The results are consistent and repeatable.
6. The results contain only facts as derived from the tests themselves.

1.5

What are the ten steps of applying the OSSTM when the 4 Point Process and Trifecta are combi

Answer Area

1. Passively collect data of normal operations to comprehend the target.
2. Actively test operations by agitating operations beyond the

Show Answer

Answers :

1. Passively collect data of normal operations to comprehend the target.
2. Actively test operations by agitating operations beyond the normal baseline.
3. Analyze data received directly from the operations tested.
4. Analyze indirect data from resources and operators (i.e. workers, programs).
5. Correlate and reconcile intelligence from direct (step 3) and indirect (step 4) data test results to determine operational security processes.
6. Determine and reconcile errors.
7. Derive metrics from both normal and agitated operations.
8. Correlate and reconcile intelligence between normal and agitated (steps 1 and 2) operations to determine the optimal level of protection and control which would best be implemented.
9. Map the optimal state of operations (step 8) to processes (step 5).
10. Create a gap analysis to determine what enhancements are needed for processes governing necessary protection and controls (step 5) to achieve the optimal operational state (step 8) from the current one.

2.1

Step 2: Gather Information About PTES.

The Penetration Testing Execution Standard is a comprehensive guide to the process of conducting penetration tests.

Navigate to www.pentest-standard.org.

What is the latest version of the standard?

Answer Area

Version 1.0

Show Answer

Answers :

This version can be considered a v1.0

2.2

What is the stated purpose of the PTES? (**Hint**: Look in the FAQs)

Answer Area

i) Pre-engagement Interactions
ii) Intelligence Gathering
iii) Threat Modeling

Show Answer

Answer :

Following are the main sections defined by the standard as the basis for penetration testing execution:

- Pre-engagement Interactions
- Intelligence Gathering
- Threat Modeling
- Vulnerability Analysis
- Exploitation
- Post Exploitation
- Reporting

2.3

What document specifies tools and techniques to be used in the seven sections of the test?

Answer Area

Technical Guidelines.

Show Answer

Answer :

PTES Technical Guidelines

This section is designed to be the PTES technical guidelines that help define certain procedures to follow during a penetration tes
been used in the industry. They will need to be continuously updated and changed upon by the community as well as within your
help during certain scenarios, but not an all encompassing set of instructions on how to perform a penetration test. Think outside



Contents [hide]

1 Tools Required
1.1 Operating Systems
1.1.1 MacOS X
1.1.2 VMware Workstation
1.1.2.1 Linux
1.1.2.2 Windows XP/7

3.1

Step 3: Gather information about the OWASP WSTG.

The OWASP WSTG is a guide for testing the security of web applications and web services. It is not a general guide to penetration testing. Instead, it focuses on developing, deploying, and maintaining secure web applications.

Navigate to https://owasp.org/www-project-web-security-testing-guide/.

What is the latest version of the WSTG standard?

Answer Area

Enter your answer here

Show Answer

Answer :

[Version 4.2] - 2020-12-03

Version 4.2 introduces new testing scenarios, updates existing chapters, and offers an improved writing style and chapter layout.

Download the v4.2 PDF here.

3.2

Access the current stable version of the WSTG. What are the five phases of the Web Security Testing Framework?

Answer Area

Enter your answer here

Show Answer

Answer :

This testing framework consists of activities that should take place:

- Before development begins,
- During definition and design,
- During development,
- During deployment, and
- During maintenance and operations.

3.3

What is the stated purpose of the OWASP WSTG?

Answer Area

Enter your answer here

Show Answer

Answer :

The WSTG is a comprehensive guide to testing the security of web applications and web services. Created by the collaborative efforts of cybersecurity professionals and dedicated volunteers, the WSTG provides a framework of best practices used by penetration testers and organizations all over the world.

3.4

What are the twelve categories of active tests defined in the OWASP Web Testing Framework?

Answer Area

Enter your answer here

Show Answer

Answer :

Active Testing

During active testing, a tester uses the methodologies described in the following sections.

The set of active tests have been split into 12 categories:

- Information Gathering
- Configuration and Deployment Management Testing
- Identity Management Testing
- Authentication Testing
- Authorization Testing
- Session Management Testing
- Input Validation Testing
- Testing for Error Handling
- Testing for Weak Cryptography
- Business Logic Testing
- Client-side Testing
- API Testing

4.1

Step 4: Gather information about MITRE ATT&CK.

MITRE ATT&CK is a detailed knowledgebase of attacker tactics, techniques, and procedures (TTP) that have been gathered from real attacks. It is not a manual or standard regarding how to conduct penetration tests. However, penetration testers can use it for ideas and guidance about how to exploit vulnerabilities as part of a test.

a. Navigate to https://attack.mitre.org.

What is the latest version of the ATT&CK standard?

Answer Area

Enter your answer here

Show Answer

Answer :

Current Version

ATT&CK v18.1
OCTOBER 28, 2025 - CURRENT

Release Notes | v18.1 Website

4.2

Why did MITRE develop ATT&CK? (**Hint**: Look in the FAQs)

Answer Area

Enter your answer here

Show Answer

Answer :

Why did MITRE develop ATT&CK?

MITRE started ATT&CK in 2013 to document common tactics, techniques, and procedures (TTPs) that advanced persistent threats use against Windows enterprise networks. It was created out of a need to document adversary behaviors for use within a MITRE research project called FMX. The objective of FMX was to investigate use of endpoint telemetry data and analytics to improve post-compromise detection of adversaries operating within enterprise networks. ATT&CK was used as the basis for testing the efficacy of the sensors and analytics under FMX and served as the common language both offense and defense could use to improve over time.

4.3

b. In the page menu click **Resources** > **General Information** > **ATT&CK Design and Philosophy**.
c. Open and review the ATT&CK Design and Philosophy pdf.

What six common use cases for ATT&CK are described?

Answer Area

Enter your answer here

Show Answer

Answer :

2 ATT&CK Use Cases

Adversary Emulation – The process of assessing the security of a technology domain by applying cyber threat intelligence about specific adversaries and how they operate to emulate that threat. Adversary emulation focuses on the ability of an organization to verify detection and/or mitigation of the adversarial activity at all applicable points in their lifecycle.

ATT&CK can be used as a tool to create adversary emulation scenarios [5] to test and verify defenses against common adversary techniques. Profiles for specific adversary groups can be constructed out of the information documented in ATT&CK (see Cyber Threat Intelligence use case). These profiles can also be used by defenders and hunting teams to align and improve defensive measures.

Red Teaming – Applying an adversarial mindset without use of known threat intelligence for the purpose of conducting an exercise. Red teaming focuses on accomplishing the end objective of an operation without being detected to show mission or operational impact of a successful breach.

ATT&CK can be used as a tool to create red team plans and organize operations to avoid certain defensive measures that may be in place within a network. It can also be used as a research roadmap to develop new ways of performing actions that may not be detected by common defenses.

Behavioral Analytics Development – By going beyond traditional indicators of compromise (IoCs) or signatures of malicious activity, behavioral detection analytics can be used to identify potentially malicious activity within a system or network that may not rely on prior knowledge of adversary tools and indicators. It is a way of leveraging how an adversary interacts with a specific platform to identify and link together suspicious activity that is agnostic or independent of specific tools that may be used.

ATT&CK can be used as a tool to construct and test behavioral analytics to detect adversarial behavior within an environment. The Cyber Analytics Repository[1] (CAR) is one example of analytic development that could be used as a starting point for an organization to develop behavioral analytics based on ATT&CK.

Defensive Gap Assessment – A defensive gap assessment allows an organization to determine what parts of its enterprise lack defenses and/or visibility. These gaps represent blind spots for potential vectors that allow an adversary to gain access to its networks undetected or unmitigated.

ATT&CK can be used as a common behavior-focused adversary model to assess tools, monitoring, and mitigations of existing defenses within an organization's enterprise. The identified gaps are useful as a way to prioritize investments for improvement of a security program. Similar security products can also be compared against a common adversary behavior model to determine coverage prior to purchasing.

SOC Maturity Assessment – An organization's Security Operations Center is a critical component of many medium to large enterprise networks that continuously monitor for active

---

threats against the network. Understanding the maturity of a SOC is important to determine its effectiveness.

ATT&CK can be used as one measurement to determine how effective a SOC is at detecting, analyzing, and responding to intrusions. Similar to the defensive gap assessment, a SOC Maturity assessment focuses on the processes a SOC uses to detect, understand, and respond to changing threats to their network over time.

Cyber Threat Intelligence Enrichment – Cyber threat intelligence covers knowledge of cyber threats and threat actor groups that impact cybersecurity. It includes information about malware, tools, TTPs, tradecraft, behavior, and other indicators that are associated to threats.

4.4

What are the three ATT&CK Technology Domains?

Answer Area

Enter your answer here

Show Answer

Answer :

3.2 Technology Domains

ATT&CK is organized in a series of "technology domains" - the ecosystem an adversary operates within that provides a set of constraints the adversary must circumvent or take advantage of to accomplish a set of objectives. To date MITRE has defined three technology domains – Enterprise (representing traditional enterprise networks and cloud technologies), Mobile (for mobile communication devices), and ICS (for industrial control systems). Within each technology domain, ATT&CK defines multiple "platforms" - the system an adversary is operating within. A platform may be an operating system or application (e.g. Microsoft Windows). Techniques and sub-techniques can apply to multiple platforms. Table 1 lists the platforms currently defined for ATT&CK technology domains except for ICS, which will be documented in a separate philosophy paper.

4.5

d. Go to the MITRE ATT&CK Enterprise matrix by opening the **Matrices** menu and choosing **Enterprise**.
e. The matrix represents tactics as column headers with techniques arranged as entries in each column. For information on a given technique, click its entry. Additional information is shown on the information page. The information page can include sub-techniques, procedures, mitigations, detection methods, and references. Not all techniques include procedures.

In the column for the **Reconnaissance** tactic, click the **Gather Victim Identity Information** entry.

Review the information there.

What are three sub-techniques that are provided for this technique?

Answer Area

Enter your answer here

Show Answer

Answer :

Gather Victim Identity Information

Sub-techniques (3)

ID	Name
T1589.001	Credentials
T1589.002	Email Addresses
T1589.003	Employee Names

4.6

f. Select the Email Addresses sub-technique. Review the information there.

Look at the entries under Procedures.

Who is the Lazarus Group? They conducted a campaign to gather email addresses for later attacks. How did they gather and use email addresses?

Answer Area

Enter your answer here

Show Answer

Answer :

G0032	Lazarus Group	Lazarus Group collected email addresses belonging to various departments of a targeted organization which were used in follow-on phishing campaigns.[17]

Reflection Questions

1. You researched four popular pentesting methodologies in this lab. Name at least two additional pentesting methodologies that are in common use.

Answer Area

NIST 800-115 & ISAAF

Show Answer

2. Why is it important to follow a recognized pentesting methodology?

Answer Area

Penetration testing helps an organization discover vulnerabilities and flaws in their systems that they might not have otherwise been able to find.

Show Answer